TECHNICAL DETAIL

Title	Business Logic Bypass: Backdating Leave Requests via Parameter Manipulation
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/leave-requests/create.
Severity	Medium
CVSS Score	4.3 CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kerentanan logika bisnis (*Business Logic Flaw*) pada fitur pengajuan cuti (*Leave Request*) di situs pegawai.my.id. Aplikasi membatasi pemilihan tanggal hanya pada sisi antarmuka pengguna (*Client-Side*), di mana pengguna tidak dapat memilih tanggal di bulan-bulan sebelumnya (masa lalu).

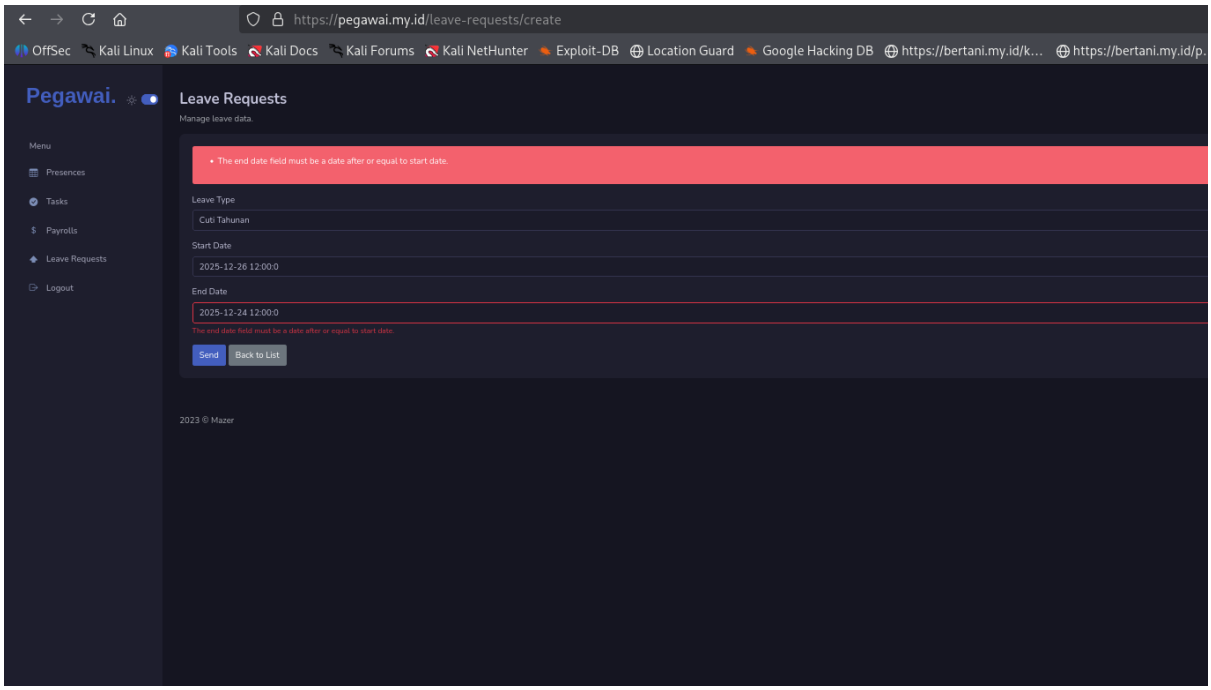
Namun, validasi ini tidak diterapkan dengan benar di sisi server (*Server-Side*). Pengguna dapat memanipulasi parameter start_date dan end_date menggunakan *Burp Suite* untuk mengajukan cuti pada tanggal yang sudah lampau (Backdating). Hal ini memungkinkan karyawan untuk memanipulasi catatan kehadiran secara retroaktif

STEPS TO REPRODUCE

1. Login ke Akun anda sebagai user di URL https://pegawai.my.id/login

2. Siapkan proxy dan burpsuite

3. buka URL https://pegawai.my.id/leave-requests/create dan masukkan format yang salah yaitu End date lebih duluan dari start date.



4. Buka burpsuite dan kirim ke reapeter

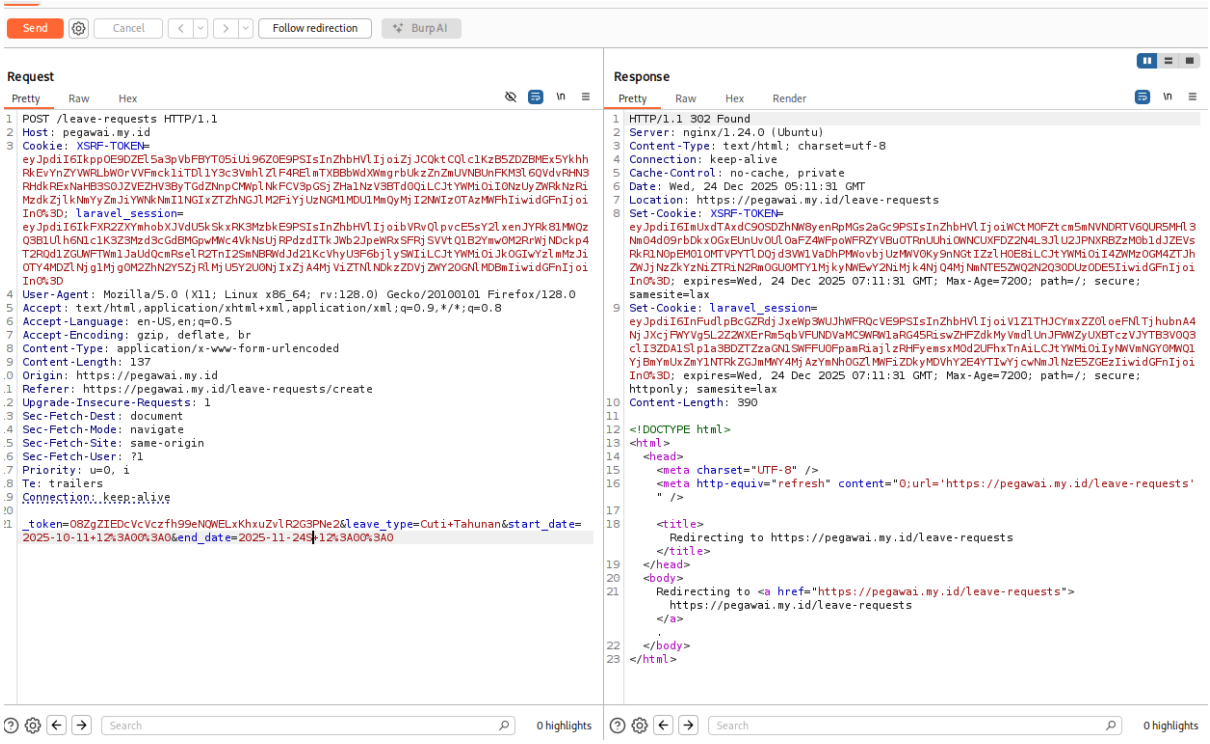
4	https://pegawai.my.id	POST	/leave-requests	✓	302
5	https://pegawai.my.id	GET	/leave-requests/create		200

Request

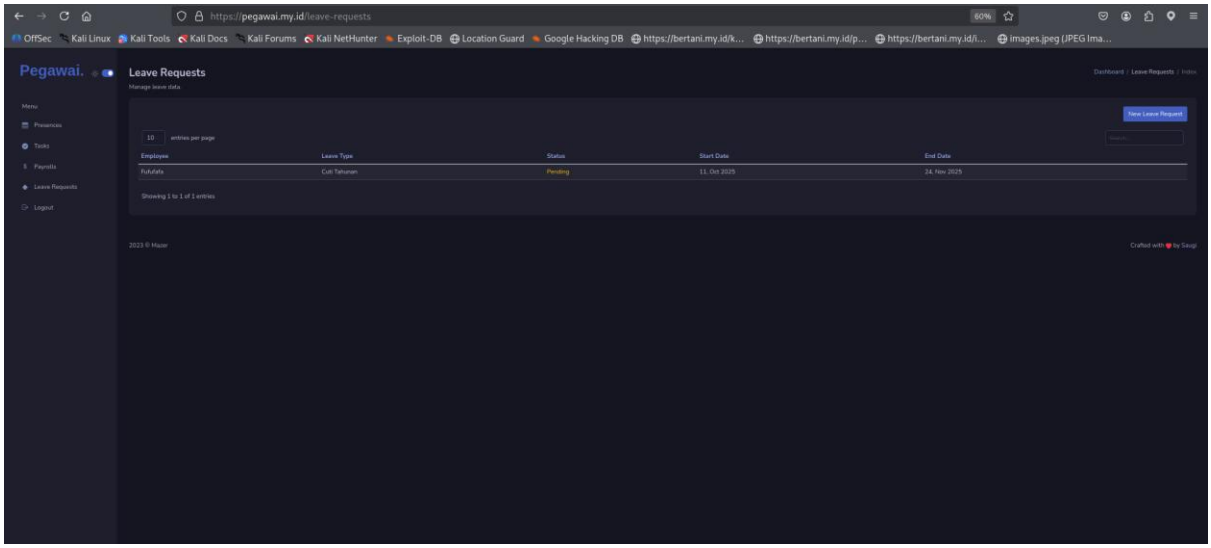
Pretty Raw Hex

```
1  POST /leave-requests HTTP/1.1
2  Host: pegawai.my.id
3  Cookie: XSRF-TOKEN=
   eyJpdiI6IkppOE9DZEl5a3pVbFBYT05iUi96Z0E9PSIsInZhbHVlIjoiZjJCQktCQlc1KzB5ZDZBMEx5Ykhh
   RkEvYnZYVWRLbW0rVVFmck1iTDl1Y3c3VmhlZlF4RElmTXBBbWdXWmgrbUkzZnZmUVNBUnFKM3l6QVdvRHN3
   RHdkRExNaHB3S0JZVEZHV3ByTGdZNnpCMWplNkFCV3pGSjZHa1NzV3BTd0QiLCJtYWMiOiI0NzUyZWRkNzRi
   MzdkZjlkNmYyZmJiYWNkNmI1NGIxZTZhNGJlM2FiYjUzNGM1MDU1MmQyMjI2NWIzOTAzMWFhIiwidGFnIjoi
   In0%3D; laravel_session=
   eyJpdiI6IkFXR2ZXYmhobXJVdU5kSkxRK3MzbkE9PSIsInZhbHVlIjoibVRvQlpvcE5sY2lxenJYRk81MWQz
   Q3B1Ulh6N1c1K3Z3Mzd3cGdBMGpwMWc4VkNsUjRPdzdITkJWb2JpeWRxSFRjSVVtQ1B2Ymw0M2RrWjNDckp4
   T2RQd1ZGUWFTWm1JaUdQcmRselR2TnI2SmNBRWdJd21KcVhyU3F6bjlySWIiLCJtYWMiOiJkOGIwYzlmMzJi
   OTY4MDZlNjg1Mjg0M2ZhN2Y5ZjRlMjU5Y2U0NjIxZjA4MjViZTNlNDkzZDVjZWY2OGNlMDBmIiwidGFnIjoi
   In0%3D
4  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
5  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6  Accept-Language: en-US,en;q=0.5
7  Accept-Encoding: gzip, deflate, br
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 137
10 Origin: https://pegawai.my.id
11 Referer: https://pegawai.my.id/leave-requests/create
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19 Connection: keep-alive
20
21 _token=O8ZgZIEDcVcVczfh99eNQWELxKhxuZvlR2G3PNe2&leave_type=Cuti+Tahunan&start_date=
   2025-12-26+12%3A00%3A0&end_date=2025-12-24+12%3A00%3A0
```

5. Ganti *start date* dan *end date* ke nilai yang tidak sesuai dengan batas minimal. Disini saya masukan start_date ke bulan oktober tahun 2025 dan end_date ke November tahun 2025 yang secara teknis tidak bisa karena saya input nya di bulan desember tahun 2025.



6. Request tetap berhasil diproses meskipun *start date* yang diinput berada di luar batas minimal yang telah ditentukan.



EXPECTED RESULT

1. Aplikasi seharusnya menerapkan validasi sisi server (*Server-Side Validation*) untuk memastikan bahwa parameter start_date tidak boleh lebih kecil dari tanggal hari ini (*Current Date*).
2. Jika pengguna mencoba mengirimkan tanggal di masa lalu melalui manipulasi parameter, server harus menolak permintaan tersebut secara otomatis.
3. Aplikasi idealnya menampilkan pesan kesalahan yang informatif, seperti "Tanggal pengajuan cuti tidak boleh surut atau di masa lampau"

ACTUAL RESULT

1. Aplikasi hanya menerapkan pembatasan pemilihan tanggal di sisi antarmuka pengguna (*Client-Side*) melalui *date picker*, namun gagal melakukan validasi di sisi server.
2. Melalui manipulasi parameter menggunakan *Burp Suite*, server menerima dan memproses pengajuan cuti untuk bulan Oktober dan November 2025, meskipun pengajuan dilakukan pada bulan Desember 2025.
3. Permintaan yang dimanipulasi tersebut berhasil tersimpan di database dengan status "Pending", yang membuktikan bahwa batasan logika bisnis berhasil dilewati secara penuh.

IMPACT

1. Attendance Fraud: Karyawan dapat mengajukan cuti untuk menutupi ketidakhadiran (bolos) di masa lalu agar tidak dipotong gaji.
2. Payroll Discrepancy: Perhitungan gaji dan tunjangan dapat menjadi tidak akurat karena manipulasi data kehadiran historis.
3. Data Integrity: Rekaman sejarah cuti pegawai menjadi tidak valid.

RECOMMENDATION

1. Server-Side Date Validation: Implementasikan pengecekan di *Backend* untuk memastikan start_date >= current_date.
2. Policy Enforcement: Jika pengajuan cuti mundur diizinkan untuk kasus tertentu, harus ada persetujuan bertingkat (*approval workflow*) yang lebih ketat, bukan diterima secara otomatis oleh sistem validasi.

REFERENCES

1. **OWASP - Testing for Business Logic Data Validation:** https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/10-Business_Logic_Testing/02-Test_Ability_to_Forge_Requests